정보보안기사 실기 23회 — 문제와 답안

원본: newbt.kr 복원 기출 (4.pdf). 답안은 복원 문항 기준의 모범 답안이며 공식 정답이 아니다.

※ 원본 PDF가 5번부터 시작해 1~4번 문항은 들어 있지 않다.

단답형

5. 유닉스의 /var/log/message 로그가 다음과 같이 기록되어 있다. 로그의 내용을 5개 항목으로 나누었을 때 ( ) 가 의미하는 바를 기술하시오.

```
[/var/log/message 샘플]
Mar 29 14:23:57(로그생성일시) alex(로그가 생성된 호스트 명) kernel:(3) [295087,236116](4) Call Trace:(5)
Mar 29 14:23:57 alex kernel: [295087,236131] do_idle+0x83/0xf0
Mar 29 14:23:57 alex systemd [1] apt-daily-upgrade.service: Consumed 50.187s CPU time
```

답안

(3) 로그를 남긴 프로세스(데몬·서비스) 이름 · **(4)** 커널 타임스탬프(부팅 후 지난 시간, 초 단위) · **(5)** 로그 메시지 내용

6. SQL Injection 취약점을 대응하는 방법에 대한 설명이다. ( ) 에 들어갈 용어를 설명하시오.

```
[공격 대상 SQL 구문]
string query = "select * from member a where gubun = '" + a.gubun "'"
[대응 방법]
외부로부터 입력받은 값을 검증하지 않고, SQL문을 생성하는데 그대로 사용하는 경우 문제가 발생할 수 있다. 즉, gubun 값으로 a' or 'a'='a 를 입력하는 경우 쿼리가 항상 참이 되므로 member 테이블의 모든 내용이 조회된다. 이에 대한 대응 방안으로 파라미터를 받는 ( ) 객체를 상수 스트링(?) 으로 정의하고, 파라미터를 setString 과 같은 메소드로 설정하면 외부의 입력이 쿼리문의 구조를 바꾸는 것을 예방할 수 있다.
```

답안

`PreparedStatement`

7. 리눅스의 PAM(Pluggable Authentication Module) 모듈의 종류에 대한 설명이다. ( )에 들어갈 모듈명을 기술하시오.

```
1) ( A ) : 실질적인 인증기능, 패스워드 확인을 담당하는 모듈
2) ( B ) : 사용자의 시스템 사용 권한을 확인하는 모듈
3) password : 패스워드를 설정하거나 확인하는 데 사용하는 모듈
4) ( C ) : 사용자가 인증 성공 시 세션을 맺어주는 모듈
```

답안

A `auth` · B `account` · C `session`

8. Salvatore Sanfilippo가 개발한 보안 테스트 툴로 ICMP, TCP, UDP 등과 같은 다양한 프로토콜을 지원한다. 다량의 공격용 패킷을 생성하여 DDoS 훈련 목적으로도 사용하는 이 툴의 이름은 무엇인가?

답안

hping(hping3)

9. 보안 점검 도구에 대하여 ( )에 들어갈 명칭을 기술하시오.

- Tripwire은 (A) 을 점검하는 도구이다.
- (B) 는 미국 Tenable사가 개발하였고, 네트워크에 연결된 다양한 종류의 시스템에 대하여 자동화된 취약점 스캔을 지원하며 광범위한 취약점 DB를 가지고 있다.

답안

A 파일 무결성 · **B** Nessus

10. CVE-2014-0160으로 알려진 오픈 SSL 취약점이다. 오픈 SSL의 하트비트 체크 로직의 취약점을 악용하여 시스템 메모리에서 중요 데이터를 탈취할 수 있는 이 취약점의 이름은 무엇인가?

답안

하트블리드(Heartbleed)

11. 위험관리 3단계에 대한 설명이다. ( )에 들어갈 단계명을 기술하시오.

(A) : 자산의 위협과 취약점을 분석하여 보안 위험의 종류와 규모를 결정하는 과정
(B) : 식별된 자산, 위협 및 취약점을 기준으로 위험도를 산출하여 기존의 보호대책을 파악하고 위험의 대응 여부와 우선 순위를 결정하기 위한 평가 과정
(대책 선정) : 허용가능 수준으로 위험을 줄이기 위해 적절하고 정당한 정보보호대책을 선정하고 이행 계획을 수립하는 과정

답안

A 위험 분석 · **B** 위험 평가

12. 위험관리를 위한 정보자산 분석 절차에 대한 설명이다. ( )에 들어갈 단계명을 기술하시오.

(A) : 보호받을 가치가 있는 자산을 식별하고, 이를 정보자산의 형태, 소유자, 관리자, 특성 등을 포함하여 자산 목록을 작성
(자산 관리자 지정) : 식별된 정보자산에 대하여 책임자 및 관리자 지정
(B) : 식별된 자산에 대해 침해 사고가 발생할 경우 그 영향을 기밀성, 무결성, 가용성 측면에서 파악하여 자산의 중요도를 산정

답안

A 자산 식별(자산 조사) · **B** 자산 중요도 평가(자산 가치 평가)

서술형

13. PHP 로 작성된 게시판의 소스코드이다. 해당 게시판의 취약점명, 업로드 로직을 우회하는 기법, 공격이 성공하기 위한 조건을 설명하시오.

```
[게시판 소스 코드]
<?
// 파일 확장자 중 업로드를 허용할 확장자를 정의함
$full_filename = explode(".", $_FILES['userfile']['name']);
$extension = $full_filename[sizeof($full_filename)-1];
if (!( ereg($extension","hwp") || ereg($extension","pdf") || ereg($extension","jpg")) )
print "업로드 금지 파일 입니다";
exit;

if (($_FILES["file"]["type"] == "image/gif") || ($_FILES["file"]["type"] == "image/jpeg") ||
($_FILES["file"]["type"] == "image/JPG") || ($_FILES["file"]["type"] == "text/plain"))
{
    echo "파일 업로드 성공"
}
else
{
    echo "파일 업로드 실패. 허용된 파일의 형식이 아닙니다."
}
?>
```

답안

취약점명: 파일 업로드 취약점(웹셸 업로드)
우회 기법: 서버가 클라이언트가 보낸 Content-Type(`$_FILES[...]['type']`)만 믿으므로, 프록시 도구로 웹셸 요청의 Content-Type을 `image/jpeg` 로 바꾼다. 확장자는 마지막 마디만 부분 일치로 검사하므로 `shell.php%00.jpg` (널 바이트)나 `shell.php.jpg` 같은 이중 확장자로 통과시킨다.
성공 조건: 업로드한 파일이 웹에서 접근 가능한 경로에 저장되고, 공격자가 그 경로를 알아야 한다. 그 디렉터리에서 서버 측 스크립트(PHP)가 실행될 수 있어야 한다.

14. TCP 헤더에 포함되어 있는 6비트의 Flag 에 대한 설명이다. ( ) 에 적절한 설명을 기술하시오.

URG : 긴급하게 전송할 데이터가 있는 경우 사용하며, 순서에 상관없이 우선순위를 높여 처리됨
PSH : 버퍼링된 데이터를 버퍼가 찰 때까지 기다리지 않고 수신 즉시 애플리케이션 계층으로 전달
SYN : (A)
ACK : (B)
FIN : (C)
RST : (D)

답안

A 연결 설정을 요청하며 초기 순서 번호를 동기화한다(3-way handshake의 시작).
B 상대가 보낸 세그먼트를 잘 받았음을 알리며, 확인 응답 번호 필드가 유효함을 나타낸다.
C 보낼 데이터가 더 없음을 알리고 연결을 정상 종료하자고 요청한다.
D 비정상 상황에서 연결을 즉시 재설정(강제 종료)한다.

15. 윈도우 OS에서 사용하는 NetBIOS 바인딩이 보안상 취약한 이유와 보안 설정하는 방법을 설명하시오.(보안 설정은 ncpa.cpl을 이용하여 설명)

답안

취약한 이유: NetBIOS가 TCP/IP에 바인딩되어 있으면 인터넷에서 `137`~`139`번 포트로 파일·프린터 공유 자원에 접근할 수 있다. 계정·공유 목록 같은 시스템 정보가 노출되고 널 세션 공격에 악용된다.
설정 방법: `ncpa.cpl` 실행 → 네트워크 어댑터 속성 → 인터넷 프로토콜 버전 4(TCP/IPv4) 속성 → 고급 → WINS 탭에서 **NetBIOS over TCP/IP 사용 안 함**을 선택한다. 필요 없으면 어댑터 속성에서 Microsoft 네트워크용 파일 및 프린터 공유도 해제한다.

16. 보안 이벤트 분석 결과 1초에 1000번 이상 다음과 같은 패킷이 유입되고 있는 것이 확인되었다. 패킷 헤더 중 a, b를 보고 어떤 공격인지 설명하시오.

```
[HTTP Request]
GET /test.jsp
Host : webserver.com
User-Agent : Mozilla/5.0
Referer : http://www.abc.com/default.jsp (a)
Cache-control : max age=0 (b)
```

답안

CC 공격(Cache-Control Attack, 캐시 제어를 이용한 HTTP GET Flooding)이다.
(a) Referer: 같은 Referer 값을 단 요청이 초당 1000번 넘게 반복된다. 정상 사용자가 아닌 봇이 같은 요청을 대량으로 보내고 있다는 뜻이다.
(b) Cache-Control: max-age=0: 캐시 서버가 저장해 둔 응답을 쓰지 말고 원본 서버에서 새로 받아 오게 한다. 그래서 캐시 서버를 우회해 웹 서버에 직접 부하를 준다.

실무형

17. 코로나 극복 후 새로운 서비스를 재개하려는 소상공인이 있다. 기존에 보유하고 있던 1만 명 미만의 고객 정보를 프리미엄 서비스에 활용하는 경우 개인정보의 안전성 확보 조치 기준에 따라 개인정보처리시스템 접근권한 관리, 접근통제를 위해 준수해야 할 사항을 기술하시오.

답안

접근권한 관리

1. 업무 수행에 필요한 최소한의 범위로, 개인정보취급자에 따라 차등 부여한다.
2. 전보·퇴직 등 인사이동이 있으면 지체 없이 권한을 변경하거나 말소한다.
3. 권한 부여·변경·말소 내역을 기록하고 최소 3년간 보관한다.
4. 개인정보취급자마다 계정을 따로 발급하고 다른 사람과 공유하지 않게 한다.
5. 비밀번호 작성 규칙을 정해 적용한다.

접근통제

1. IP 주소 등으로 접속 권한을 제한하고, 불법 접근 시도를 탐지·대응하는 침입 차단·탐지 기능을 둔다.
2. 외부에서 접속할 때는 VPN·전용선 같은 안전한 접속 수단이나 안전한 인증 수단을 쓴다.
3. 홈페이지·P2P·공유 설정으로 권한 없는 자에게 개인정보가 노출되지 않게 한다.
4. 일정 시간 이상 업무를 하지 않으면 접속이 자동으로 차단되게 한다.

18. Korea.co.kr 도메인의 존 파일을 설정하려고 한다. MASTER와 SLAVE DNS 서버의 named.conf 설정값을 각각 작성하시오. (zone 파일은 ns.korea.co.kr.zone 이다)

- master name 서버 : ns1.korea.co.kr (192.168.1.53)
- slave name 서버 : ns2.korea.co.kr (192.168.2.53)

답안

Master (ns1, 192.168.1.53)

```
zone "korea.co.kr" IN {
    type master;
    file "ns.korea.co.kr.zone";
    allow-transfer { 192.168.2.53; };
};
```

Slave (ns2, 192.168.2.53)

```
zone "korea.co.kr" IN {
    type slave;
    file "slaves/ns.korea.co.kr.zone";
    masters { 192.168.1.53; };
};
```

allow-transfer로 영역 전송을 슬레이브에만 허용해 존 정보 유출을 막는다.